Processo de Assegurar a Segurança

Documento de Especificação (Procedimento)

Ref. COBIT® – DS5.9

ÍNDICE

1. OBJETIVO 3
2. ESCOPO DO PROCESSO 3
3. OBJETIVOS DE CONTROLE COBIT 4.1 3
4. CONCEITOS 3
5. DIRETRIZES E DEFINIÇÕES DO PROCESSO 4
6. INTERFACE COM OUTROS PROCESSOS 5
7. FLUXOGRAMAS 6
8. DESCRIÇÃO DAS ATIVIDADES DOS FLUXOGRAMAS 7
9. MATRIZ RACI 10
10. PAPÉIS E RESPONSABILIDADES 11
11. INDICADORES 11
12. DOCUMENTOS DE APOIO 12
13. CONTROLE DE VERSÃO 12

1. Objetivo

Este processo tem como objetivo assegurar que medidas preventivas de detecção e correção sejam estabelecidas na Smiles em relação a aplicação de Patches e proteção dos Sistemas de Tecnologia da Informação contra *malwares* (vírus, worms, spywares).

2. Escopo do Processo

O processo "Assegurar a Segurança" tem como escopo garantir de forma eficiente a atualização do antivírus e aplicação dos Patches de segurança nas Estações de Trabalho, Servidores do Datacenter do Escritório Central e do Datacenter da Amazon, considerando apenas os equipamentos com sistema operacional Microsoft Windows instalado e de responsabilidade da área de TI da Smiles.

3. Objetivos de Controle COBIT 4.1

Processo / Objetivos de Controle	Situação	Análise sobre o processo atual
DS5 - Garantir a Segurança dos Sistemas		
DS5.9 Prevenção, Detecção e Correção de Software Malicioso Assegurar que medidas preventivas de detecção e corretivas sejam estabelecidas corporativamente, em especial correções de segurança (patches) e controles de vírus, para proteger os sistemas de informação e tecnologias contra malwares (vírus, worms, spyware, spam.).	**Contemplado**	O processo contempla medidas preventivas para realizar correções de segurança e controle de vírus visando proteger os sistemas de TI Smiles contra malwares e vulnerabilidades.

4. Conceitos

A seguir estão os principais conceitos do processo:

- **Serviço de TI:** equivale ao conjunto de recursos computacionais (hardware, serviços de software e software) utilizados para processar, armazenar e transmitir informações eletrônicas, incluindo sistemas de informação, serviços baseados em nuvem, aplicações web, entre outros.
- **Patch:** equivale ao conjunto de correções desenvolvidas para interromper disfunções ou vulnerabilidades em sistemas, que são identificados e recomendados por fornecedores. Normalmente são classificados pelos próprios fornecedores de acordo com sua criticidade.
- **Antivírus:** são programas de computador concebidos para prevenir, detectar e eliminar vírus de computador e outros malwares.

- **Malware:** termo do inglês "*malicious software*", é um *software* destinado a infiltrar-se em um sistema de computador alheio de forma ilícita, com o intuito de causar alguns danos, alterações ou roubo de informações (confidenciais ou não). Ele pode aparecer na forma de código executável, scripts de conteúdo ativo e outros softwares. "*Malware*" é um termo geral utilizado para se referir a uma variedade de formas de software hostil ou intruso.

- **Spyware:** programa que tem como objetivo monitorar atividades de um sistema e enviar as informações a terceiros. Podem ser usados de forma legítima, mas geralmente, são usados de forma dissimulada, não autorizada e maliciosa (espião).

- **Vacina:** entende-se por vacina as atualizações que o antivírus deve aplicar para que a ameaça seja removida.

- **Vírus:** programa com fins maliciosos, capaz de causar transtornos com os mais diversos tipos de ações: há vírus que apagam ou alteram arquivos dos usuários, que prejudicam o funcionamento do sistema operacional danificando ou alterando suas funcionalidades, que causam excesso de tráfego em redes e assim por diante.

- **Worm:** programa semelhante aos vírus, com a diferença de este ser auto replicante, ou seja, ele cria cópias funcionais de si mesmo e infecta outros computadores. Tal infecção pode ocorrer através de conexões de rede locais, Internet ou anexos de e-mails.

5. Diretrizes e Definições do Processo

O processo possui as seguintes diretrizes e definições:

- **Patch Crítico:** serão considerados Patches Críticos pela Smiles, aqueles que foram avaliados pela área de Infraestrutura de TI e possam impactar diretamente as operações de negócios.

- **Instalação de antivírus em Estações de Trabalho:** a obrigatoriedade de instalação de antivírus em estações de trabalho é garantida pelo Documento Normativo de Padrões de Microinformática da Smiles. Nesse documento a ferramenta de antivírus é considerada software padrão.

- **Instalação de antivírus em Servidores:** a obrigatoriedade de instalação do antivírus em servidores elegíveis é de responsabilidade e deve ser garantida pela equipe de Infraestrutura de TI.

- **Estação de Trabalho:** nome genérico dado a computadores de mesa (desktops ou laptops) usado pelos colaboradores da Smiles, comumente identificados como usuários.

- **Servidores Elegíveis:** servidores instalados no Datacenter do Escritório Central e no Datacenter da Amazon, considerando apenas aqueles que possuem sistema operacional Microsoft Windows instalados.

- **Verificação e Avaliação de Patches:** a verificação e avaliação de Patches ocorre semanalmente, tanto para servidores elegíveis, quanto para estações de trabalho.

- **Atualização de Patches Faseada:** foram definidos Grupos de Equipamentos compostos por Servidores Elegíveis e/ou Estações de Trabalho na Ferramenta Microsoft (console central de administração) para aplicação de Patches na Smiles.
    - A dinâmica de aplicação dos Patches consiste na distribuição gradual dos Patches, inicialmente para um Grupo de Testes (grupo composto por uma menor quantidade de Servidores Elegíveis e/ou Estações de Trabalho), de forma a garantir a validação do comportamento dos Patches. Na sequência, os mesmos serão liberá-los para o restante do parque (*rollout*).
    - Para aplicação de Patches em Servidores Elegíveis é mandatória a abertura de uma Mudança (GMUD). No caso de Patches Críticos a aplicação deve ser realizada de forma emergencial, através da abertura de uma GMUD Emergencial.
    - Para aplicação de Patches em Estações de Trabalho, o procedimento de distribuição é transparente aos usuários e não requer abertura de Mudança (GMUD).

- **Verificação de novas Vacinas contra vírus:** a verificação de novas vacinas é realizada diariamente, de forma automática, pela console central da ferramenta de antivírus.

- **Aplicação de novas Vacinas contra vírus:** a distribuição e aplicação de uma nova vacina para o parque de Estações de Trabalho e Servidores Elegíveis, ocorre automaticamente quando a mesma é identificada pela console central da ferramenta de antivírus. Caso não haja atualização no dia, não haverá distribuição/aplicação.

- **Varredura do Antivírus:** ações de detecção e monitoramento contra vírus são realizadas diariamente, de forma automática, através de varredura nas Estações de Trabalho e Servidores Elegíveis.

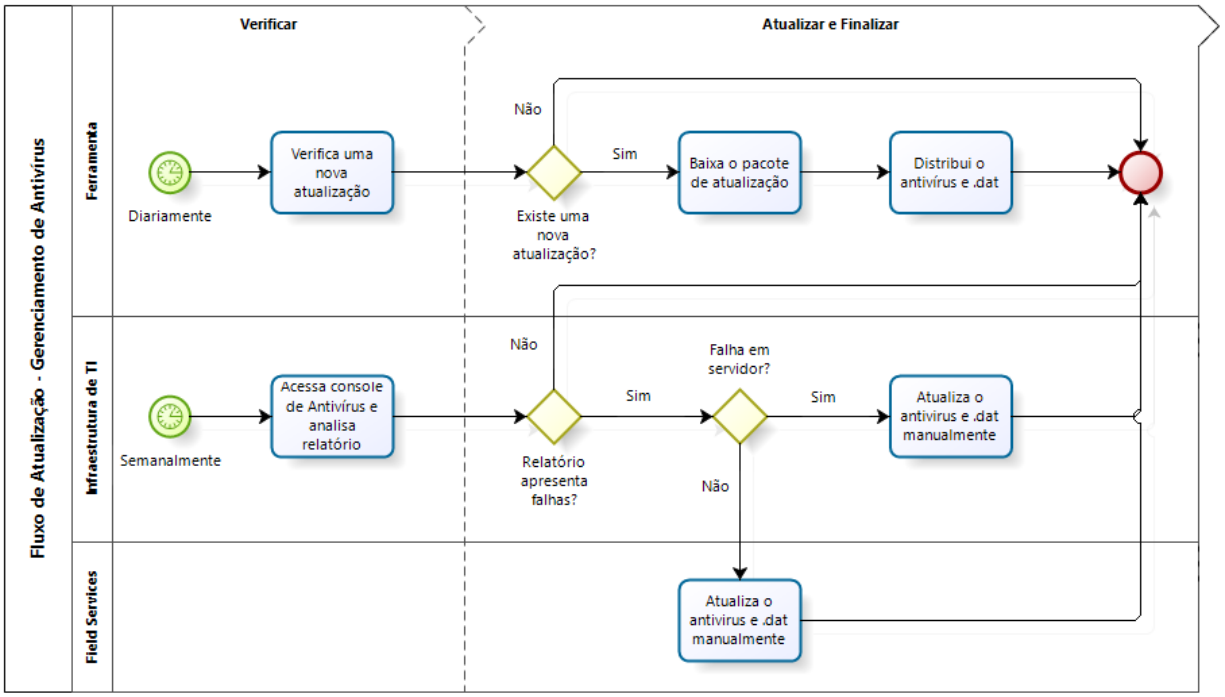
6. Interface com outros processos

- **Gerenciamento de Incidentes de Segurança da Informação**
    - A área de Segurança da Informação registrará Incidentes de Segurança da Informação quando for identificada a ausência de atualização de Patches Críticos e/ou ausência da ferramenta de antivírus em Servidores Elegíveis e Estações de Trabalho.

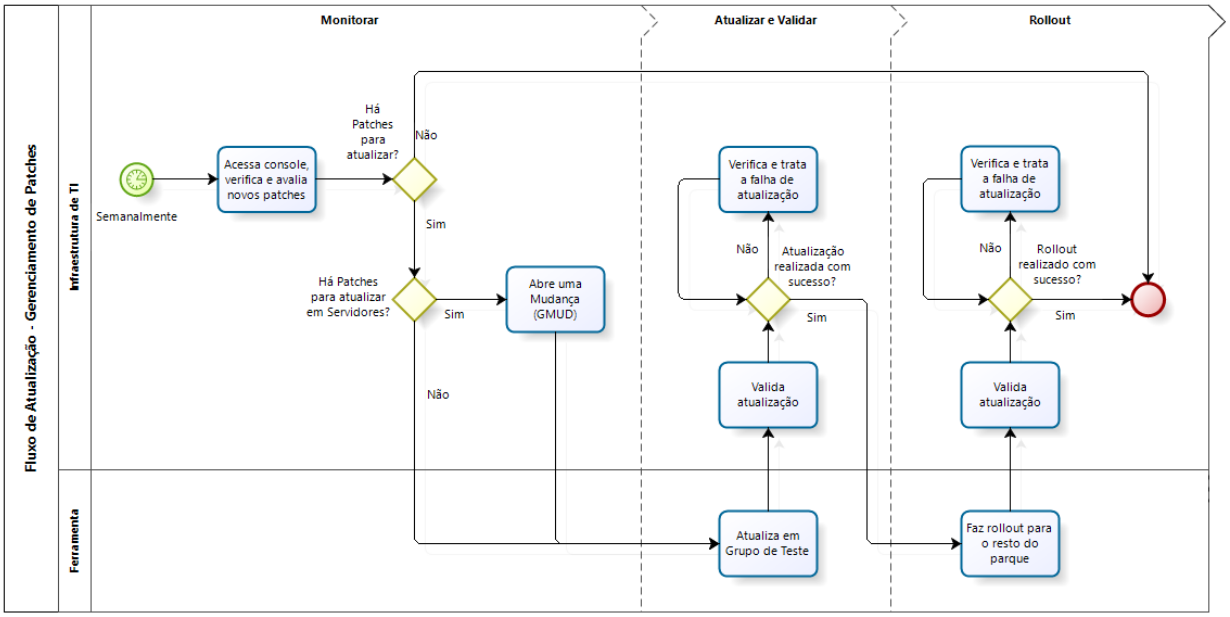
- **Gerenciamento de Mudanças**
    - Para aplicação de Patches em Servidores Elegíveis requer o registro de uma Mudança (GMUD).

7. Fluxogramas

Fluxograma de Atualização – Gerenciamento de Antivírus



Fluxograma de Atualização – Gerenciamento de Patches



8. Descrição das Atividades dos Fluxogramas

Atividades do Fluxograma de Atualização – Gerenciamento de Antivírus

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Verifica uma nova atualização	Ferramenta de Antivírus	Nesta atividade a Ferramenta de Antivírus verifica automaticamente se há nova atualização de Antivírus e .dat. Diariamente a Ferramenta de Antivírus verifica disponibilidade de novas atualizações. Caso identifique nova atualização do antivírus e .dat a ferramenta baixa o pacote de atualização. (Segue para o passo 02) Caso não identifique nova atualização do antivírus e .dat a ferramenta aguarda novo ciclo de verificação de atualização. (Segue para o passo 01)	01 ou 02
02	Baixa o pacote de atualização	Ferramenta de Antivírus	Nesta atividade a Ferramenta de Antivírus baixa o pacote de atualização. Após identificar nova atualização de antivírus, a ferramenta baixa o pacote para atualizar a versão do antivírus e .dat nos Servidores Elegíveis e Estações de Trabalho.	03
03	Distribui o antivírus e .dat	Ferramenta de Antivírus	Nesta atividade a Ferramenta de Antivírus atualiza o Antivírus e .dat. Após baixar o pacote de atualização do antivírus e .dat, a Ferramenta de Antivírus distribui a atualização para Servidores Elegíveis e Estações de Trabalho com a nova versão.	Fim do Fluxo
04	Acessa console de Antivírus e analisa relatório	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura acessa o console de Antivírus e analisa o relatório. Semanalmente a equipe de Infraestrutura de TI acessa o console de Antivírus e analisa o relatório de atualizações para identificar falhas ou pendências de atualizações em Servidores Elegíveis e Estações de Trabalho. Caso o relatório não apresente falhas, a equipe de Infraestrutura aguarda próxima semana para nova análise. (Fim) Caso o relatório apresente falhas de atualização em Servidor, a equipe de Infraestrutura de TI atualiza o antivírus e .dat manualmente. (Segue para o passo 05) Caso o relatório apresente falhas de atualização em Estações de Trabalho, a equipe de Field Services atualiza o antivírus e .dat manualmente. (Segue para o passo 06)	Fim do Fluxo, 05 ou 06
05	Atualiza o antivírus e .dat manualmente	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI atualiza o antivírus e .dat manualmente. Ao identificar falha de atualização em Servidores Elegíveis, a equipe de Infraestrutura atualiza o antivírus e .dat manualmente	Fim do Fluxo
06	Atualiza o antivírus e .dat manualmente	Field Services	Nesta atividade a equipe de Field Services atualiza o antivírus e .dat manualmente. Ao identificar falha de atualização em Estações de Trabalho, a equipe de Field Services atualiza o antivírus e .dat manualmente.	Fim do Fluxo

Atividades do Fluxograma de Atualização – Gerenciamento de Patches

Passo	Atividade	Executor	Descrição	Passo Seguinte
01	Acessa console, verifica e avalia novos patches	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI acessa o console, verifica e avalia os novos Patches disponíveis. Semanalmente, a equipe de Infraestrutura de TI acessa o console de administração centralizada da Microsoft (Ferramenta Microsoft) e verifica existência de novos Patches. Na sequência, avalia a aplicabilidade dos novos Patches ao cenário e ambiente da Smiles, aceitando os aplicáveis e declinando os não aplicáveis. Caso seja existam novos Patches aplicáveis nos Servidores Elegíveis da Smiles, a equipe de Infraestrutura de TI irá realizar a abertura de uma GMUD (Segue para o passo 02). Caso seja existam novos Patches aplicáveis nas Estações de Trabalho da Smiles, a equipe de Infraestrutura de TI irá promover sua atualização, primeiramente no Grupo de Testes (Segue para o passo 03). Caso não existam novos Patches ou apenas Patches NÃO aplicáveis ao cenário e ambientes da Smiles, a equipe de Infraestrutura de TI aguarda novo ciclo para verificação e avaliação de novos Patches. (FIM)	02, 05 ou Fim do Fluxo
02	Abre uma Mudança (GMUD)	Infraestrutura de TI	Nesta atividade, a equipe de Infraestrutura de TI realiza a abertura de uma Mudança (GMUD). Após ter verificado que há Patches aplicáveis nos Servidores Elegíveis, a equipe de Infraestrutura de TI realiza a abertura de uma Mudança (GMUD) através da ferramenta JIRA, com a finalidade de obter autorização para execução da atualização e posterior reinicialização dos servidores afetados.	03
03	Atualiza em Grupo de Teste	Ferramenta Microsoft	Nesta atividade a Ferramenta Microsoft (console central de administração) atualiza o Grupo de Testes. Após a verificação da existência e da aplicabilidade de novos Patches nos Servidores Elegíveis e/ou nas Estações de Trabalho da Smiles, a Ferramenta Microsoft (console de administração centralizada da Microsoft) promove a atualização dos referidos Patches no Grupo de Testes (grupo que contém uma pequena parte desses equipamentos). Cabe ressaltar que a atualização nos Servidores Elegíveis apenas ocorrerá após a aprovação da Mudança (GMUD).	04
04	Valida atualização	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI valida a atualização dos Patches no Grupo de Testes. Após atualização dos novos Patches aplicáveis no Grupo de Testes, a equipe de Infraestrutura de TI acessa a Ferramenta Microsoft (console de administração centralizada da Microsoft) e valida se as atualizações foram concluídas com êxito. Caso as atualizações no Grupo de Testes não tenham sido realizadas com sucesso, a equipe de Infraestrutura de TI deverá verificar e tratar as falhas identificadas. (Segue para o passo 05) Caso as atualizações no Grupo de Testes tenham sido realizadas com sucesso, a equipe de Infraestrutura de TI deverá promover o *rollout* dos Patches para o resto dos Servidores Elegíveis e/ou Estações de Trabalho. (Segue para o passo 06)	05 ou 06
05	Verifica e trata a falha de atualização	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI verifica e trata as falhas de atualização de Patches identificadas no Grupo de Testes. Após ter identificado que ocorram falhas na atualização de Patches no Grupo de Testes, a equipe de Infraestrutura de TI verifica na Ferramenta Microsoft (console de administração centralizada da Microsoft) quais erros ocorreram e promove sua tratativa/correção. Uma vez eliminados os erros de atualização, a equipe de Infraestrutura de TI deverá promover o *rollout* dos Patches para o resto dos Servidores Elegíveis e/ou Estações de Trabalho. (Segue para o passo 06).	06

Passo	Atividade	Executor	Descrição	Passo Seguinte
06	Faz *rollout* para o resto do parque	Ferramenta Microsoft	Nesta atividade a Ferramenta Microsoft (console central de administração) realiza o *rollout* dos Patches para o restante dos Servidores Elegíveis e/ou Estações de Trabalho. Após a validação da atualização bem-sucedida no Grupo de Testes, a Ferramenta Microsoft (console de administração centralizada da Microsoft) promove a atualização (*rollout*) dos referidos Patches para o restante dos Servidores Elegíveis e/ou Estações de Trabalho. Cabe ressaltar que a atualização nos Servidores Elegíveis continua condicionada à Mudança (GMUD) que já havia sido aberta e aprovada.	07
07	Valida atualização	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI valida a atualização (*rollout*) dos Patches no restante dos Servidores Elegíveis e/ou Estações de Trabalho. Após atualização (*rollout*) dos novos Patches aplicáveis no restante dos Servidores Elegíveis e/ou Estações de Trabalho, a equipe de Infraestrutura de TI acessa a Ferramenta Microsoft (console de administração centralizada da Microsoft) e valida se as atualizações foram concluídas com êxito. Caso as atualizações (*rollout*) não tenham sido realizadas com sucesso, a equipe de Infraestrutura de TI deverá verificar e tratar as falhas identificadas. (Segue para o passo 08) Caso as atualizações (*rollout*) tenham sido realizadas com sucesso, a equipe de Infraestrutura de TI aguarda novo ciclo para verificação e avaliação de novos Patches. (FIM)	08 ou Fim do Fluxo
08	Verifica e trata a falha de atualização	Infraestrutura de TI	Nesta atividade a equipe de Infraestrutura de TI verifica e trata as falhas de atualização de Patches identificadas no *Rollout*. Após ter identificado que ocorram falhas na atualização de Patches no *Rollout*, a equipe de Infraestrutura de TI verifica na Ferramenta Microsoft (console de administração centralizada da Microsoft) quais erros ocorreram e promove sua tratativa/correção. Uma vez eliminados os erros de atualização, a equipe de Infraestrutura de TI aguarda novo ciclo para verificação e avaliação de novos Patches. (FIM)	Fim do Fluxo

9. Matriz RACI

RACI Smiles	Assegurar a Segurança Fluxo de Atualização - Gerenciamento de Antivírus R = Responsible | A = Accountable | C = Consulted | I = Informed Executor | Principal Responsável | Consultado | Informado	CIO	Infraestrutura de TI	Infraestrutura	Field Services
Passo	Atividades				
	Responsável pelo sucesso do processo	**A**			
01	Verifica uma nova atualização		R	I	
02	Baixa o pacote de atualização		R	I	
03	Distribui o antivírus e .dat		R	I	
04	Acessa console de Antivírus e analisa relatório			R	
05	Atualiza o antivirus e .dat manualmente			R / I	
06	Atualiza o antivirus e .dat manualmente			I	R

RACI Smiles	Assegurar a Segurança Fluxo de Atualização - Gerenciamento de Patches R = Responsible | A = Accountable | C = Consulted | I = Informed Executor | Principal Responsável | Consultado | Informado	CIO	Infraestrutura de TI	Ferramenta
Passo	Atividades			
	Responsável pelo sucesso do processo	**A**		
01	Acessa console, verifica e avalia novos patches		R	C
02	Abre uma Mudança (GMUD)		R	
03	Atualiza em Grupo de Teste			R
04	Valida atualização		R	C
05	Verifica e trata a falha de atualização		R	
06	Faz rollout para o resto do parque			R
07	Valida atualização		R	C
08	Verifica e trata a falha de atualização		R	

10. Papéis e Responsabilidades

- **Infraestrutura de TI**
  - Responsável pelo gerenciamento dos Patches e Antivírus nos Servidores Elegíveis e Estações de Trabalho da Smiles (instalação, atualização e validação).
  - Responsável pela instalação manual de atualizações de Antivírus nos Servidores Elegíveis em decorrência de falha da atualização automática.
  - Responsável por garantir a elaboração dos indicadores de desempenho do processo.
- **Field Services**
  - Responsável pela instalação manual de atualizações de Antivírus nas Estações de Trabalho em decorrência de falha da atualização automática.
- **Segurança da Informação**
  - Responsável por realizar a acompanhamento dos indicadores do processo. Caso seja identificado algum desvio, a área de Segurança da Informação deve abrir um Incidente de Segurança para tratamento e direcionamento adequados das ações corretivas.
- **Governança de TI**
  - Responsável por garantir a publicação dos indicadores de desempenho do processo.

11. Indicadores

Para o processo Assegurar a Segurança, temos definidos os seguintes indicadores:

- **Gerenciamento de Patches (Indicador Trimestral):**
  - Quantidade e Percentual de Equipamentos atualizados
  - Quantidade e Percentual de Equipamentos NÃO atualizados ou NÃO aplicados
- **Gerenciamento de Antivírus (Indicador Mensal):**
  - Quantidade e Percentual de Equipamentos protegidos / total de Equipamentos ativos
  - Quantidade e Percentual de Equipamentos inativos ou não instalados / total de Equipamentos

Nota: Equipamentos = Servidores Elegíveis e Estações de Trabalho

12. Documentos de Apoio

- Processo de Gerenciamento de Mudanças
- Política de Segurança da Informação
- Documento Normativo de Padrões de Microinformática

13. Controle de Versão

Versão	Data	Responsável	Principais Alterações
1.0	06/01/2017	CHACON Consultoria	Primeira versão do documento.
1.1	04/04/2017	CHACON Consultoria	Inclusão da Análise dos Objetivos de Controle do COBIT. Revisão e melhorias gerais (formatação e redação para melhor compreensão do processo).